Audit de l'application JAMAAL — 14 octobre 2026

Périmètre : dépôt `jamaal-git` (branche `main`) et site en ligne `https://jamaal-nine.vercel.app`. Méthode : contrôles automatiques, revue du code des accès et des paiements, sondage du site en ligne **sans session**. Ce document est un rapport d'audit avec preuves ; ce n'est pas une certification délivrée par un organisme tiers.

1. Contrôles automatiques

Contrôle	Résultat
TypeScript (`tsc --noEmit`)	0 erreur
ESLint (tout le projet)	0 erreur, 0 avertissement
Tests (`npm test`)	163 réussis, 0 échec, **21 ignorés** (tests qui exigent une base PostgreSQL)
Build de production (`next build`)	réussi
Audit des dépendances (`npm audit --omit=dev`)	6 avis restants (voir §4)
Secrets dans le dépôt	aucun (recherche de clés, mots de passe, URL de base de données)

2. Sécurité — ce qui a été vérifié et jugé conforme

- **Actions d'administration** : les 23 fonctions d'écriture (produits, consultants, coupons, retours, utilisateurs, paiements de commissions, réglages, visuels) commencent toutes par un contrôle d'accès administrateur.
- **Pages d'administration** : préfixes réservés à l'administrateur dans `src/proxy.ts` ; les pages restantes (espace revendeur, assistant, notifications) ont leur propre garde.
- **Données d'autrui** : une commande de revendeur n'est lisible que par son revendeur ; les protocoles signés sont limités à leur signataire et aux administrateurs.
- **Points d'entrée API sans session** (testés en ligne) : exports, diagnostics, cron, relais Chogan, assistant d'administration, parrainage, promotions, visuels : tous refusés (401, 403 ou 405).
- **Webhooks** : Wave, Orange Money, Stripe, Versus et WhatsApp refusent tout appel non signé (401 ou 503). Le webhook Versus relit le paiement chez Versus avant de valider.
- **Prix** : le serveur recontrôle chaque prix de commande contre le catalogue (un client ne peut pas imposer un prix).
- **Limitation de débit** : assistant de la boutique, paiement, commande ; verrouillage du compte après échecs de connexion.
- **Injection / XSS** : les 11 requêtes SQL brutes sont toutes des gabarits paramétrés (`$queryRaw` avec valeurs liées, aucun `Unsafe`) ; le seul `dangerouslySetInnerHTML` (un script constant sur la facture d'administration, sans donnée utilisateur) a été remplacé par un composant : il n'en reste aucun ; aucun `eval` ni `child_process` hors tests.

- **En-têtes** : CSP, HSTS (préchargement), X-Frame-Options DENY, nosniff, Referrer-Policy, Permissions-Policy. Cookies d'authentification `HttpOnly`, `Secure`, `SameSite=Lax`.
- **Site en ligne** : 27 pages publiques testées, aucune erreur serveur ; `robots.txt` exclut l'administration et l'API.

3. Corrections apportées pendant l'audit

1. **Tests** : trois tests échouaient sous Windows (chemins `C:\C:\…` dans trois scripts d'import ; faux `python3` du Microsoft Store dans le test ZIP). Corrigés : la suite passe de 3 échecs à 0.
2. `npm test` n'exécutait aucun test sous Windows (guillemets simples) : corrigé, la commande fonctionne partout.
3. **Référencement** : 12 pages publiques partageaient le même titre générique. Chacune a désormais un titre et une description propres (collections avec le nom de la catégorie ; panier et liste de souhaits exclus de l'indexation).
4. La page de facture d'administration n'utilise plus de script en ligne (composant d'impression), un obstacle de moins à un futur CSP strict.
5. Corrections des jours précédents : adresses de retour Versus en `https`, libellé de paiement, message de bienvenue, dépendances `next` 16.4.0 et `sharp` 0.35.5.

4. Risques restants et décisions à prendre

#	Sujet	Gravité	Détail
1	Mot de passe Neon exposé dans une conversation	**Haute**	À changer, puis mettre à jour `DATABASE_URL` et `DATABASE_URL_UNPOOLED` sur Vercel.
2	Mots de passe de démonstration (« Jamaal2026 »)	**Haute**	À remplacer avant ouverture au public.
3	Versus pointe vers le **staging** en production	**Haute**	Les clients voient un paiement de test. Retirer les variables `VERSUS_*` de Production ou passer aux identifiants de production.
4	CGV : texte « site de démonstration, aucun paiement réel »	Moyenne	À rédiger ou faire valider avant mise en production.
5	CSP avec `script-src 'unsafe-inline'`	Moyenne	Réduit la protection contre le XSS. Essai de CSP à nonces (15 octobre) : fonctionne en local mais Vercel n'applique pas le nonce aux scripts (cause non identifiée) ; l'imposer casserait le site. Essai retiré, politique inchangée. Piste : tester sur un déploiement d'aperçu avec la journalisation Vercel.
6	6 avis de dépendances	Faible	`deepmerge-ts`, `mysql2` (outils internes de Prisma, non appelés à l'exécution) ; `uuid` via `exceljs` (non exploitable ici). Corrections forcées = retour arrière de `prisma` et `exceljs`.
7	21 tests de base de données ignorés	Faible	À exécuter dans un environnement avec une base PostgreSQL de test.

#	Sujet	Gravité	Détail
8	Photos Chogan servies depuis le CDN du fournisseur	Faible	À héberger chez vous pour ne plus dépendre d'un tiers.
9	Secrets Wave / Orange Money / Stripe non définis	Info	Sans effet tant que Versus est utilisé.
10	Mode de paiement enregistré « Wave » pour les paiements Versus	Info	Libellé corrigé côté client ; les frais comptables par moyen restent calculés comme Wave.
11	Avant le premier paiement, la fiche de commande affiche « À la livraison »	Info	Cosmétique.

5. Ce qui n'a pas pu être vérifié

- Les 21 tests qui exigent une base de données.
- Les écrans connectés (administrateur, revendeur, livreur) : aucune session de test n'était disponible, donc les droits ont été vérifiés par lecture du code et par sondage sans session, pas par navigation réelle.
- L'envoi réel de messages WhatsApp (prestataire non configuré, messages simulés).
- Un paiement Versus de bout en bout et la réception réelle de son webhook.
- Performance sous charge, accessibilité complète (lecteur d'écran), conformité juridique (RGPD / droit sénégalais).

Document provisoire généré à partir de docs/audit-2026-10-14.md. Ce rapport n'est pas une certification délivrée par un organisme tiers.